

Report Setup Lab e IOC Hunting

S9L1

1. Obiettivo

L'esercitazione S9L1 ha come obiettivo la configurazione di un laboratorio di analisi malware basato su **FlareVM** e l'identificazione di **Indicatori di Compromissione (IOC)** tramite analisi del Registro di Windows e triage su VirusTotal. L'attività prevede la creazione di uno snapshot pulito della VM, l'avvio del repository malware tramite script PowerShell, il calcolo degli hash dei campioni e la ricerca approfondita su VirusTotal per estrarre domini C2, chiavi di registro e comportamenti sospetti.

Nota: Tutte le attività sono state eseguite esclusivamente all'interno dell'ambiente virtuale isolato (FlareVM su UTM). Nessun malware è stato eseguito su sistemi reali. L'esercitazione è svolta a fini didattici.

2. Fase 1 - Setup FlareVM e Snapshot Clean

Step 1 Verifica configurazione rete FlareVM

Prima di procedere con l'analisi, è stata verificata la configurazione di rete della FlareVM per assicurarsi che la VM operasse in un segmento isolato e non avesse accesso a reti esterne non controllate.

Step 2 Creazione snapshot 'Clean'

Prima di avviare qualsiasi script o analisi, è stato creato uno snapshot pulito della FlareVM. Questo snapshot rappresenta lo stato baseline della macchina con sistema operativo integro, registro pulito, nessun malware attivo e consente di ripristinare l'ambiente in modo rapido al termine di ogni sessione di analisi.

Nota: Lo snapshot Clean è fondamentale nella metodologia malware analysis: permette di confrontare lo stato pre/post esecuzione e garantisce la riproducibilità dell'analisi su campioni diversi.

Step 3 Avvio script malwareRepo.ps1

Dalla cartella Desktop della FlareVM è stato avviato lo script PowerShell `malwareRepo.ps1`, che ha scaricato e organizzato nella cartella `malware\` i campioni da analizzare.

```
# Avvio script da PowerShell (run as Administrator)
Set-ExecutionPolicy Bypass -Scope Process -Force
.\malwareRepo.ps1

# Output atteso:
[*] Downloading malware samples...
[+] Samples extracted to C:\Users\flare\Desktop\malware\
```

3. Fase 2 - Calcolo Hash dei Campioni

Step 1 Estrazione campioni dalla cartella malware

Dalla cartella malware\ sono stati selezionati tre campioni da analizzare. I file sono stati estratti (decompressi) utilizzando le utility integrate di FlareVM, prestando attenzione a non eseguirli.

Step 2 Calcolo SHA256 tramite menu contestuale

Per ogni campione estratto è stato calcolato l'hash SHA256 utilizzando la funzione nativa di FlareVM accessibile tramite clic destro → Hash. L'hash è l'identificatore univoco del file e viene utilizzato per la ricerca su database di threat intelligence come VirusTotal.

I tre campioni selezionati dalla cartella malware (dopo decompressione) sono stati analizzati con **HashMyFiles** di NirSoft, preinstallato in FlareVM, che calcola simultaneamente MD5 e SHA-256 per tutti i file selezionati:

[illegible]

4. Fase 3 - IOC Hunting su VirusTotal

Per ogni hash SHA256 calcolato è stata effettuata una ricerca su **VirusTotal**. Per ciascun campione sono stati analizzati tre aspetti chiave: il **Detection Ratio** (quanti AV rilevano il file come malevolo), il tab **Behavior** (comportamento dinamico: processi, connessioni, modifiche al registro), e il tab **Relations** (domini C2 contattati, URL, file correlati).

Campione 1 BlueScreen.exe - HackTool NirSoft (14/72)

Il file BlueScreen.exe corrisponde al tool legittimo **StartBlueScreen** di NirSoft, progettato per innescare intenzionalmente un Blue Screen of Death (BSOD). Il campione utilizza **UPX packing** per offuscare il codice ed esegue operazioni di basso livello: richiesta di SeLoadDriverPrivilege e SeDebugPrivilege, rilascio del driver kernel NirSoftBlueScreenDriver.sys e registrazione come servizio in SYSTEM\CurrentControlSet\Services.

SHA256	14e6ac84d824c0cf6ea8ebb5b3be10f8893449474096e59ff0fd878d49d0c160
Detection Ratio	14 / 72 - Popular threat label: hacktool
Famiglia	HackTool - NirSoft StartBlueScreen (distributore noto)
Relations C2	Solo domini Microsoft legittimi (0/91 detection)
Registro - IOC	HKLM\SYSTEM\CurrentControlSet\Services\NirSoftBlueScreenDriver
MITRE ATT&CK;	Defense Evasion (T1574), Anti-Analysis, Anti-Static Analysis

Nota: Pur essendo un tool distribuito da NirSoft (vendor noto), le sue capacità di manipolazione del kernel e induzione di crash di sistema lo rendono pericoloso in contesti malevoli. 14 AV lo classificano come hacktool.

Campione 2 HawkEye.exe - Chimera Ransomware (64/71)

Nonostante il nome HawkEye.exe, questo campione è **Chimera Ransomware** (MSIL/.NET), una delle famiglie ransomware più pericolose per la doppia tattica: cifratura dei file e minaccia di pubblicazione dei dati. Il malware contatta bot.whatismyipaddress.com per identificare l'IP pubblico della vittima (confermato da Sigma Rule), usa **mega.nz** per l'esfiltrazione dei dati e rilascia la nota di riscatto YOUR_FILES_ARE_ENCRYPTED.HTML. Zenbox lo classifica come MALWARE RANSOM EVADER, VMRay come SPREADER.

SHA256	1dacdc296fd6ef6ba817b184cce9901901c47c01d849adfa4222bfabfed61838
Detection Ratio	64 / 71 - Popular threat label: trojan.chimera/msil
Famiglia	Chimera Ransomware - Family labels: chimera, msil, crypchim
C2 - IP Recon	bot.whatismyipaddress.com (Sigma Rule: Suspicious DNS IP Lookup)
Esfiltrazione	mega.nz (presente nei Memory Pattern Domains)
Ransom Note	YOUR_FILES_ARE_ENCRYPTED.HTML
Registro - IOC	HKCU\CurrentVersion\Internet Settings\ProxyEnable (modificato)
MITRE ATT&CK;	Persistence, Stealth (11 tecniche), Credential Access T1056, C2 T1071

La Sigma Rule 'Suspicious DNS Query for IP Lookup Service APIs' è scattata sul processo: il malware interroga bot.whatismyipaddress.com da un processo non-browser - comportamento tipico di ransomware e RAT per il fingerprinting della rete vittima.

Campione 3 InfinityCrypt.exe - HiddenTear/InfinityLock (62/71)

Il file InfinityCrypt.exe ha come vero nome originale **PremiereCrack.exe** un classico vettore di social engineering che si spaccia per una crack di Adobe Premiere Pro (icona dell'applicazione originale). È basato su **HiddenTear** (ransomware open-source) con overlay **InfinityLock**. Opera in modalità offline (nessun C2 esterno): utilizza il provider crittografico di Windows (Cryptography\Defaults\Provider Types\Type 024) per la cifratura dei file, ai quali appende un hash identificativo. MITRE ATT&CK; T1547 conferma l'uso di **Boot/Logon Autostart Execution** per la persistenza.

SHA256	f5d002bfe80b48386a6c99c41528931b7f5df736cd34094463c3f85dde0180bf
Detection Ratio	62 / 71 - Popular threat label: ransomware.msil/hiddentear
Famiglia	HiddenTear / InfinityLock - Family labels: msil, hiddentear, infinitylock
Vero nome file	PremiereCrack.exe (icon spoofing: Adobe Premiere Pro)
C2	204.79.197.203:443 (Microsoft - ransomware offline, no C2 esterno)
Registro - IOC	HKLM\SOFTWARE\Microsoft\Cryptography\Defaults\Provider Types\Type 024
Persistenza	Boot/Logon Autostart Execution (MITRE T1547)
MITRE ATT&CK;	Persistence T1547, Cryptography OC0005, Collection T1560

Dr.Web vxCube: RANSOM MALWARE. I file cifrati ricevono come suffisso l'hash 600F8C5402C9071E...FCE4803 - IOC diretto per rilevare file cifrati da InfinityLock sui sistemi colpiti.

5. Fase 4 (Bonus) - Persistenza nel Registro HKCU\Run

Step 1 Creazione chiave di persistenza manuale con regedit

Per simulare una tecnica di persistenza comunemente usata dai malware, è stata creata manualmente tramite **regedit** una chiave di tipo String Value nel percorso

HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run. Questo percorso viene letto da Windows ad ogni avvio utente: qualsiasi valore presente viene eseguito automaticamente.

```
# Percorso registro aperto con regedit:
HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run

# Valore creato:
Nome: Persistence_Key
Tipo: REG_SZ (String Value)
Dato: cmd.exe

# Altre chiavi presenti (preesistenti FlareVM):
OneDrive → C:\Program Files\Microsoft OneDrive\OneDrive.exe
ZoomIt → C:\Tools\sysinternals\ZoomIt64.exe
```

Step 2 Verifica effetto al riavvio

Dopo aver creato la chiave Persistence_Key → cmd.exe, la FlareVM è stata riavviata. Al login, una finestra di cmd.exe si è aperta automaticamente (Microsoft Windows versione 10.0.26100.1742, hostname FLARE-VM, prompt in C:\Users\User\Desktop), confermando il meccanismo di persistenza. In uno scenario reale, al posto di cmd.exe sarebbe presente il path del malware.

La chiave HKCU\Run non richiede privilegi elevati (a differenza di HKLM\Run), rendendola particolarmente appetibile per malware non privilegiati e tecniche di privilege escalation differite.

6. Tabella IOC Compilata

Di seguito la tabella riepilogativa degli Indicatori di Compromissione identificati tramite l'analisi su VirusTotal per i tre campioni analizzati.

Campione	SHA256	Det.	Dominio C2	Chiave Registro
BlueScreen.exe	14e6ac84d824c0cf6ea8...	14/72	Nessun C2 malevolo (solo domini Microsoft)	...Run\NirSoftBlueScreenDriver
HawkEye.exe	1dacdc296fd6ef6ba817...	64/71	bot.whatismyipaddress.com / mega.nz	...Run\ProxyEnable
InfinityCrypt.exe	f5d002bfe80b48386a6c...	62/71	204.79.197.203:443 (ransomware offline)	...Run\Type 024

Gli IOC raccolti (hash, domini C2, chiavi di registro) possono essere importati direttamente in strumenti SIEM/EDR per attivare alert automatici in caso di rilevamento nelle reti aziendali.

7. Bonus - Analisi con LLM e Valutazione Risposta AI

Gli IOC raccolti (hash, domini C2 e chiavi di registro) sono stati sottoposti a un modello LLM per ottenere una valutazione della famiglia malware, delle tecniche MITRE ATT&CK associate e dei possibili vettori di attacco. Di seguito una sintesi dei risultati e una valutazione critica della completezza della risposta AI.

Osservazione: L'LLM ha fornito una descrizione accurata delle famiglie malware e dei pattern comportamentali generali, ma ha mostrato limiti nella correlazione puntuale degli hash con campagne specifiche e nella disponibilità di IOC aggiornati oltre la sua data di training. La ricerca diretta su VirusTotal rimane insostituibile per dati in tempo reale.

8. Conclusioni

L'esercitazione ha permesso di configurare un laboratorio di analisi malware professionale su FlareVM (Windows 11 24H2) e di applicare un workflow completo di **IOC Hunting**. I tre campioni analizzati hanno rivelato famiglie distinte con livelli di pericolosità crescente: **BlueScreen.exe** (14/72 - HackTool NirSoft, tool legittimo riclassificato), **HawkEye.exe** (64/71 - Chimera Ransomware con C2 recon su whatismyipaddress.com e esfiltrazione su mega.nz), e **InfinityCrypt.exe** (62/71 - HiddenTear/InfinityLock travestito da crack Adobe Premiere). Il bonus sulla persistenza ha confermato empiricamente come la chiave HKCU\Run\Persistence_Key → cmd.exe abbia prodotto l'apertura automatica del terminale al riavvio, meccanismo identico a quello usato dai ransomware per garantire la propria sopravvivenza sul sistema.

Vulnerabilità / Famiglia Malware	Gravità	Contromisura
Chimera Ransomware (HawkEye.exe) - cifratura + esfiltrazione dati su mega.nz	Critica	Blocco DNS bot.whatismyipaddress.com e mega.nz; EDR con behavioral rules
InfinityLock/HiddenTear (InfinityCrypt.exe) - cifratura offline con T1547	Critica	Monitoraggio Run key; backup offline; blocco esecuzione da %TEMP%
BlueScreen HackTool (BlueScreen.exe) - kernel driver BSOD exploit	Alta	Blocco caricamento driver non firmati; monitoraggio HKLM\Services
Persistenza HKCU\Run simulata - autoavvio senza privilegi elevati	Alta	Alert su scritture HKCU\Run via Sysmon Event ID 13; EDR + allowlist

DISCLAIMER: Tutte le tecniche descritte sono state applicate esclusivamente in ambiente virtuale isolato (FlareVM su UTM) a fini didattici. L'utilizzo non autorizzato su sistemi reali è illegale ai sensi del Codice Penale italiano (art. 615-ter, 635-bis, 617-quater).